

ClubLens v12

Data Protection Risk Assessment

Prepared by	Paul Ottewell
Date	April 2026
Tool reviewed	ClubLens v12
Intended audience	Data Protection Officer
Classification	Internal — Restricted
Review trigger	Before any new version is distributed

RESTRICTED — This document contains a technical and legal assessment of data protection risks relating to the processing of personal data, including special category data, about children. It is intended solely for the Data Protection Officer and authorised personnel. It must not be shared beyond those parties without the approval of the DPO.

1. What ClubLens Does

ClubLens is a tool used by school leaders to analyse which pupils are participating in clubs, and which priority groups — such as pupils eligible for Pupil Premium, those with special educational needs, or those in the care of the local authority — may be underrepresented. It is designed to support safeguarding review, strategic planning, and preparation for inspection.

The tool is a single HTML file that runs entirely within a web browser on a local device. It reads a spreadsheet exported from the school's Bromcom management information system and generates analysis on-screen. **No data is sent to any server, website, or third party at any point.** The tool has been built to be fully offline: once the file is open, it makes no network connections of any kind.

When the browser tab is closed, all pupil data is discarded. The tool has no database, no server, and no persistent record of pupil information between sessions. The only data that persists between sessions is free-text action plan notes typed by the user, which are saved to the browser on the local device only, and contain no pupil names or sensitive data.

2. Personal Data Processed

The following personal data is read from the Bromcom spreadsheet. All of it exists only in the browser's memory during the session and is never written to disk or transmitted externally.

Category	Data field	Special category under UK GDPR?
Identity	Preferred first name, preferred last name	No

Education	Year group, club memberships by term	No
Welfare	Pupil Premium eligibility (Ever FSM 6 flag)	No
Special educational needs	SEN status: EHCP or SEN Support (K)	Yes — health / disability
Language	English as an Additional Language (EAL) flag	No
Family circumstances	Service Children in Education flag	No
Looked after status	Pupil Premium Looked After flag	Yes — social care

Because the tool processes EHCP status and Looked After flags, it processes **special category personal data** as defined in Article 9 of the UK GDPR. All data subjects are children. These two facts set the baseline for the risk assessment that follows: the tolerance for any exposure of this data is zero.

3. How Data Moves Through the Tool

Understanding where data goes — and crucially where it does not go — is central to this assessment. The diagram below summarises the data flows.

Step	What happens	Data leaves device?
1. Upload	The user selects a Bromcom .xlsx file from their local device. The file is read by the browser into temporary memory.	No
2. Analysis	The tool processes the data in memory and displays analysis on-screen: participation rates, priority group breakdowns, club membership lists.	No
3. Action Plan	The user may type free-text action notes into the Action Plan tab. These notes contain no pupil data. They are saved to the browser on the local device only (browser localStorage).	No
4. PDF export	The Action Plan can be printed to PDF. The print document contains only group-level percentages and counts — no individual pupil names or sensitive attributes.	No
5. Session end	When the browser tab is closed, all pupil data is discarded from memory. Nothing is retained on the device or anywhere else.	N/A — data deleted

The tool's offline design has been technically verified. A security rule embedded in the tool itself — called a Content Security Policy — instructs the browser to refuse all outbound network connections. This is enforced at the browser level and cannot be overridden by the page content. A code audit confirmed that no network-calling code (such as fetch, XMLHttpRequest, or WebSocket) exists anywhere in the tool.

4. Security Design

ClubLens has been built with a number of deliberate security measures. This section explains each in plain terms.

Security feature	What it does
No network connections	The browser is instructed to block all outbound connections. Even if someone were to modify the tool, it could not send data anywhere.
No external scripts or fonts	Every piece of code the tool needs — including the Excel parsing library — is contained within the single HTML file. Nothing is loaded from the internet at any point.
Script integrity checking	The browser verifies the code it runs by checking it against a pre-computed fingerprint (a cryptographic hash). If the code has been tampered with, the browser will refuse to run it.
HTML injection protection	All data read from the spreadsheet is sanitised before being displayed on screen. This prevents a specially crafted spreadsheet file from injecting malicious content into the page.
No inline event handlers	Buttons and interactive elements are wired up through safe, structured code. This closes a common class of web security vulnerability.
Anonymisation toggle	A button in the header replaces all pupil names on screen with tokens (Pupil 001, Pupil 002...) for use when presenting on a shared screen.
No pupil data in PDF export	The Action Plan PDF contains only group-level statistics and free-text notes. It contains no pupil names, SEN codes, or Looked After flags.
URL-safe club name handling	Club names containing special characters (apostrophes, ampersands, etc.) are encoded before being placed in HTML attributes, preventing them from breaking the page structure.

5. Outstanding Risks

The following risks have been identified through a technical audit of the ClubLens v12 source code. Each risk is rated using four levels:

Rating	Meaning
Medium	A real vulnerability that should be addressed before wider deployment. Does not by itself block use in a controlled pilot setting with appropriate training.
Low	A weakness worth addressing in a future version, or one that can be managed through procedural controls rather than a code change.
Accepted	A known limitation that cannot be resolved within the current design, where the residual risk has been assessed as manageable with named controls and is suitable for recording in a DPIA.

Risk 1	Pupil data is visible to anyone with access to the device while the tool is open	Medium
What this means		

When a spreadsheet is loaded into ClubLens, all of its contents — including names, SEN codes, and Looked After flags — are held in the browser's working memory for the duration of the session. This is how all browser-based tools of this kind operate; it is not a flaw specific to ClubLens. However, it means that anyone who gains physical access to the machine while the tab is open, and who knows how to open browser developer tools (a freely available feature in all browsers), can view the full dataset in memory.

This risk cannot be eliminated within a browser-based tool. It is entirely dependent on physical access controls to the device.

Consequence if unaddressed

If the tool is left open on an unattended device — for example at the end of a meeting or during a break — the full pupil dataset, including special category data, would be accessible to any person who reaches the keyboard.

Recommendation

Users must be given clear guidance that closing the browser tab is the equivalent of locking away a paper file. The tool should never be left open on an unattended machine, and should not be used on shared or hot-desk computers. A future version of the tool should include an automatic timeout that clears all data after 30 minutes of inactivity.

Risk 2 No automatic timeout: data remains in memory until the tab is closed

Low

What this means

ClubLens does not automatically clear pupil data after a period of inactivity. Once a spreadsheet is loaded, the data remains in the browser's memory until the user manually closes the tab. There is no warning that data is still loaded, and no prompt to close the tab when the user steps away.

This directly compounds Risk 1: the longer the tab remains open and unattended, the greater the window of opportunity for someone else to access the device.

Consequence if unaddressed

A user who is interrupted mid-session and walks away from their desk without closing the tab leaves all pupil data exposed indefinitely — potentially for hours.

Recommendation

Implement an inactivity timeout in a future version. The recommended approach is for the tool to clear all loaded data and return to the start screen after 30 minutes without user interaction, displaying a message explaining that the session has expired for security reasons. In the meantime, user training must explicitly require closing the browser tab when stepping away from the workstation.

Risk 3 Action plan notes are accessible to other local HTML files in the same browser

Low

What this means

The Action Plan tab allows users to type free-text notes about their plans for each priority group. These notes are saved to a feature of the browser called localStorage, which allows web pages to store small amounts of text on the local device between sessions.

When a file is opened directly from a computer (rather than from a web server), all locally-opened HTML files share the same storage space in the browser. This means that another HTML file opened from the same browser profile could, in theory, read the action plan notes.

Importantly, the notes themselves contain no pupil names, SEN codes, or other personal data from the spreadsheet. They contain only the free-text plans that the user has typed. However, those plans may contain sensitive strategic content, such as intended interventions for named priority groups.

Consequence if unaddressed

If an untrusted HTML file were opened in the same browser profile, it could potentially read the action plan notes. In practice this requires the machine to be used by multiple people, or for an untrusted file to be opened deliberately or accidentally.

Recommendation

This limitation cannot be fixed without adding a server component, which would change the fundamental offline design of the tool. The recommended approach is to record this as an accepted risk in the DPIA, with the named control that the machine must be used only by authorised staff and that no untrusted HTML files are opened in the same browser profile.

Risk 4 No record is kept of who used the tool, when, or what data was loaded

Low

What this means

ClubLens keeps no log of activity. There is no record of when the tool was opened, which spreadsheet was loaded, or what the user did during a session. The Action Plan PDF export likewise leaves no trace within the tool.

This is a structural consequence of the fully offline, no-server design. Adding an audit log would require a server component.

Consequence if unaddressed

If a data incident occurred — for example, if a printout containing pupil data were found in an insecure location — the tool would provide no information to help investigate what happened, when, or who was involved. Investigation would depend entirely on other sources such as device activity logs.

Recommendation

Access to ClubLens should be restricted to a named list of authorised staff, and a simple access register should be maintained outside the tool — for example in a shared folder or spreadsheet — recording who has been granted access and when. This register substitutes for the in-tool audit log that the offline architecture cannot provide.

Risk 5 The tool checks a file's name but not whether it is genuinely an Excel file

Low

What this means

When a file is dragged and dropped onto ClubLens, the tool checks that its name ends in .xlsx before attempting to open it. It does not look inside the file to confirm it is genuinely a spreadsheet.

In practice, any file with a .xlsx extension is passed to the Excel parsing library. That library is mature and has its own input validation, but relying solely on a filename check as the first line of defence is a single point of failure.

Consequence if unaddressed

A specially constructed file — for example one that mimics an Excel filename but contains unexpected content — would be passed directly to the parsing library without any prior check. The realistic risk is low, given that files would ordinarily come directly from a Bromcom export, but it represents an unnecessary gap.

Recommendation

A future version should verify that the uploaded file begins with the correct internal signature for an Excel file (the first four bytes of all valid .xlsx files follow a known pattern). This adds a meaningful layer of validation before the file is parsed. Users should also be reminded in their training that the tool should only be used with exports generated directly from Bromcom.

Risk 6 The Excel parsing library cannot be independently updated

Accepted

What this means

The library that ClubLens uses to read Excel files (SheetJS) is built into the HTML file itself. This was a deliberate design decision to make the tool fully self-contained and offline. The consequence is that if a security vulnerability were discovered in SheetJS, the tool would need to be rebuilt and redistributed to incorporate a fix; there is no mechanism for the library to update itself.

SheetJS is a widely used, mature open-source library. The specific version in use has no known vulnerabilities at the time of this assessment.

Consequence if unaddressed

If a vulnerability were discovered in the version of SheetJS bundled with ClubLens, users of existing copies of the file would remain exposed until a new version is distributed and the old file replaced.

Recommendation

Record as an accepted risk in the DPIA. As a named control: the person responsible for the tool (Paul Ottewell) should monitor SheetJS release notes for security advisories, and a new version of ClubLens should be issued promptly if a relevant vulnerability is identified. The access register recommended under Risk 4 will ensure that any updated version can be distributed to all authorised users.

6. Risk Summary

Risk	Summary	Severity	Blocks pilot use?
1	Data visible on unattended device	Medium	No — training required

2	No automatic session timeout	Low	No — training required
3	Action plan notes in shared browser storage	Low	No — accepted risk
4	No audit log of access or exports	Low	No — access register required
5	File type check relies on filename only	Low	No
6	Excel parsing library cannot self-update	Accepted	No — accepted risk

None of the risks identified in this assessment block the distribution or use of ClubLens v12 in a controlled setting with appropriate training and access controls. All risks are either low severity, accepted by design, or manageable through the procedural controls described above.

7. Recommendation on DPIA Requirement

The processing of special category personal data (specifically EHCP status and Looked After flags) relating to children is likely to meet the ICO's threshold for a formal Data Protection Impact Assessment (DPIA) under Article 35 of the UK GDPR. The ICO's published screening criteria include: processing of special category data; processing relating to children; and systematic monitoring. This tool meets at least the first two criteria.

A formal DPIA is recommended before the tool is used beyond the current pilot testing phase.
The DPIA should address the following:

Area	What the DPIA should address
Processing basis	The lawful basis for processing. Given that the data controller is a public authority (a school within a Multi-Academy Trust), the most likely basis is Article 6(1)(e) (public task) with Article 9(2)(b) or 9(2)(f) for special category data. The DPO should confirm the appropriate basis.
Access controls	A named list of authorised users should be established and maintained. Access should be limited to headteachers and designated safeguarding leads or equivalent senior staff with a legitimate need to see individual pupil data.
User training	All authorised users must receive briefing covering: the requirement to close the browser tab when stepping away; the prohibition on using the tool on shared or hot-desk machines; and the importance of only loading files exported directly from Bromcom.
Device security	The machines on which ClubLens is used should be subject to appropriate physical and access controls: screen locks, full-disk encryption, and restricted access to authorised personnel only.
Risks 3 and 6 as accepted risks	The browser storage sharing limitation (Risk 3) and the bundled library update limitation (Risk 6) should be formally recorded as accepted risks in the DPIA with the controls described in Section 5.
Review cadence	The DPIA should be reviewed before any new version of ClubLens is deployed, and at least annually.

8. Document Control

Document title	ClubLens v12 — Data Protection Risk Assessment
Tool reviewed	ClubLens v12
Prepared by	Paul Ottewell (in a personal capacity)
Reviewed by	[DPO name — to be completed by DPO]
DPO review date	[To be completed by DPO]
Next review	Before any new version of ClubLens is distributed
Classification	Internal — Restricted

RESTRICTED — Internal use only. Do not distribute beyond the DPO and authorised personnel without the approval of the DPO.